Technical Documentation: Autonomous Agent Wallet & Deterministic Risk Control Plane

Competition: 2026 Shenzhen International FinTech Competition (FinTechathon) - International Track
Topic: Topic F - Agent Wallet (Autonomous On-chain Wallet)
GitHub Repository: https://github.com/Crux-15/agent-wallet

1. System Architecture (Control Plane vs. Execution Plane)

Our architecture enforces a strict privilege boundary between the Cognitive Layer (LLM intent translation) and the Execution Layer (deterministic policy verification and cryptographic transaction signing). The AI model never holds private keys, never accesses Web3 signing objects, and cannot bypass safety rules.

```
[User / Operator UI: Streamlit Web Control Center (app.py) & CLI (agent.py)]
       |
       v
[Cognitive Layer (agent.py): Gemini Function-Calling + Local Regex Fallback Router]
       |  (Emits structured requests across 6 whitelisted tools; MAX_ROUNDS = 5)
       v
[Security Guard Layer (executor.py): ToolExecutor + Human Approval Gate + AuditLog]
       |---> 1. Policy Check ---> [PolicyEngine (policy.py): Tiers 0/1/2, Risk Score 0-100]
       |---> 2. Execution    ---> [ExecutionAdapter: MockAdapter | ChainAdapter (Sepolia)]
```

2. Core Algorithm Description

A. Seven-Stage Fail-Closed Policy Pipeline (policy.py):
Every outgoing payment request is evaluated in strict order using exact decimal.Decimal math:
1. Tier Lock Check: If tier == READ_ONLY (0), deny immediately.
2. Address Validation: Verify recipient matches ^0x[0-9a-fA-F]{40}$ and apply EIP-55 checksum.
3. Exact Decimal Positivity: Reject NaN, Infinity, non-numbers, or amounts <= 0.
4. Allowlist Enforcement: Verify recipient address is in the approved recipient set.
5. Per-Tx & Rolling 24h Caps: Reject if amount > 0.01 ETH or if spent_last_24h() + amount > 0.05 ETH.
6. Reserve Floor & Gas Ceiling Guard: Reject if balance - amount < 0.002 ETH or if live gas > 50 Gwei.
7. Human Supervisor Escalation: If tier == APPROVE_ALL (1) or amount > 0.002 ETH, require human approval.

B. Quantitative Risk Scoring Algorithm (0 to 100):
Each transaction receives a composite risk score R in [0, 100]: +60 for unapproved/invalid address, up to +40 scaled by transaction size relative to the 0.01 ETH cap, +15 if above the 0.002 ETH approval threshold, +35 if breaching the 24h cap, and +25 if network gas exceeds 50 Gwei. Scores map to LOW (0-19), MEDIUM (20-39), HIGH (40-69), and CRITICAL (70-100).

C. EIP-1559 Dynamic Gas & Commit-After-Receipt State Accounting:
ChainAdapter constructs EIP-1559 transactions with a 20% gas estimate buffer. PolicyEngine.record() is called ONLY after wait_for_transaction_receipt confirms status == 1 on Ethereum Sepolia, ensuring denied or failed calls never deplete the daily spending budget.

3. Security Design & On-Chain Execution Evidence

- Prompt Injection Defense: Untrusted prompts claiming 'admin mode' cannot bypass PolicyEngine.check().

- Persistent Spend State: Rolling 24h spend records persist to logs/policy_state.json across restarts.
- Secret Redaction: AuditLog (logs/audit.jsonl) records only exception class names so RPC keys never leak.
- Automated Verification: 50 pytest unit tests passing across adapters, policy, executor, and agent.

Confirmed Ethereum Sepolia Testnet Transactions (Approved Recipient: 0x78964c29614bF783c3339cd7b553C8627168554E):

1. Auto-Executed (0.0005 ETH, Risk 1/100 LOW, 2026-10-19 22:44:00):
   Hash: 0xd03fff8dc8ba123539f97cab7dd456c9487535c446df01674aee8cee6524a0a4
2. Human-Approved (0.0022 ETH, Risk 21/100 MEDIUM, 2026-10-19 22:44:38):
   Hash: 0xbde5dd8c3f4e0ffdd0afae4ae95ae29e58f183618a17314e07495a323ac17cc0